

Metasploitable 2

Full Enumeration Notes

A structured walkthrough of the reconnaissance & enumeration phase against a Metasploitable 2 target — service discovery, misconfiguration analysis, and attack-surface mapping.

Target	10.174.253.161 (Metasploitable 2)
Scope	Network connectivity, port scanning, FTP, SMB, NFS, Telnet, HTTP, Tomcat, MySQL, PostgreSQL, DNS, Java RMI, IRC
Phase	Enumeration only — no exploitation performed
Sessions	Part 1 (Monday) — Core services Part 2 (Monday, cont.) — Web, database & remaining services

Table of Contents

Day 1 — Core Service Enumeration

1. Goal of Enumeration
2. Connectivity Check (Ping & ARP)
3. Initial & Full Port Scanning (Nmap)
4. FTP Enumeration
5. SMB Enumeration
6. NFS Enumeration & Mounting
7. Reading Remote Files
8. Telnet Enumeration
9. Enumeration vs Exploitation
10. Key Mindset — Observe / Hypothesize / Test / Conclude

Part 2 — Continued Enumeration (Remaining Services)

Goal of This Enumeration Phase

10. Apache HTTP Enumeration — Port 80
11. Apache Tomcat Enumeration — Port 8180
12. MySQL Enumeration — Port 3306
13. PostgreSQL Enumeration — Port 5432
14. DNS Enumeration — Port 53
15. Java RMI Enumeration — Ports 1099 / 40380
16. IRC Enumeration — Ports 6667 / 6697

Difference Between Enumeration and Exploitation

Key Mindset Learned

Overall Outcome

DAY 1 — MONDAY — CORE SERVICE ENUMERATION

1 Goal of Enumeration

The purpose of enumeration is **not** to hack the target immediately. The goal is to gather as much information as possible about every exposed service before deciding what to attack.

Think of a target machine as a collection of attack surfaces rather than a single computer.

2 Connectivity Check

Ping

```
ping 10.174.253.161
```

PURPOSE & RESULT

- Verify the target is alive.
- Measure latency.
- Confirm network connectivity before scanning.
- **Result:** Host responded successfully.

ARP

```
arp -a
```

PURPOSE

- Verify that the target is on the local network.
- Learn the target's MAC address.

3 Port Scanning (Nmap)

Initial Port Scan

```
nmap 10.174.253.161
```

Purpose: quickly discover open TCP ports. This is only the first overview of exposed services.

Full Enumeration Scan

```
nmap -sV -sC -p- 10.174.253.161 -oN monday_scan.txt
```

Command / Option	Meaning
-sV	Detect service versions.
-sC	Run Nmap's default safe enumeration scripts.
-p-	Scan all 65535 TCP ports.
-oN	Save output to a text file.

Important Findings

OPEN SERVICES DISCOVERED

- FTP (vsftpd 2.3.4)
- SSH
- Telnet
- SMTP
- DNS
- Apache HTTP
- SMB
- NFS
- MySQL
- PostgreSQL
- Tomcat
- Java RMI
- IRC
- Distccd
- VNC
- X11

4 FTP Enumeration

```
ftp 10.174.253.161
```

Logged in as: anonymous | Password: (blank)

Observations

OBSERVATIONS

- Anonymous login allowed.
- Nmap temporarily logged in during scanning to gather information.
- The Nmap output showing "Logged in as ftp" referred only to the temporary scan session, not a permanent login.
- After Nmap finished scanning, it disconnected automatically.

Commands Used

```
pwd
ls
dir
```

Result: Login successful. Directory listing available. Root directory contained no visible files.

Upload Test

```
put testformeta.txt
```

```
553 Could not create file.
```

MEANING

- Anonymous uploads are not allowed.
- Anonymous users appear to have read-only access.

5 SMB Enumeration

List Available Shares

```
smbclient -L //10.174.253.161 -N
```

Command / Option	Meaning
-L	List available SMB shares.
-N	Authenticate anonymously (null session).

Discovered Shares

SHARES FOUND

- print\$
- tmp
- opt
- IPC\$
- ADMIN\$

Anonymous login was successful.

Accessing a Share

```
smbclient //10.174.253.161/tmp -N
```

```
ls  
help  
get .X0-lock
```

Findings

FINDINGS

- Anonymous users can access the tmp share.
- Directory listing works.
- Files can be downloaded anonymously.

Downloaded file: .X0-lock → Contents: 4689 (most likely the PID of the X11 server).

KEY LESSON

- The important finding was **not** the file contents themselves.
- The important finding was that anonymous users could successfully download files.

6 NFS Enumeration

List Exported Directories

```
showmount -e 10.174.253.161
```

```
/
*
```

Command / Option	Meaning
/	The root filesystem is exported.
*	Any client is allowed to access the export.

MEANING

- This is an extremely permissive NFS configuration.

7 Understanding Mounting

```
mkdir ~/nfs
sudo mount -t nfs 10.174.253.161:/ ~/nfs
```

Command / Option	Meaning
mount	Attach another filesystem.
-t nfs	Filesystem type is NFS.
10.174.253.161:/	Remote exported root directory.
~/nfs	Local directory where it will appear.

Important Concept

CONCEPT

- Mounting does **not** copy files.
- Instead, Linux makes the remote filesystem appear inside a local directory.
- *Analogy: it is like attaching another computer's hard drive into one of your own folders.*

```
ls ~/nfs
```

TARGET'S REAL DIRECTORIES DISPLAYED

- bin
- boot
- etc
- home
- root
- usr
- var

8 Reading Remote Files

```
cat ~/nfs/etc/passwd
```

IMPORTANT LEARNING

- This did **not** read a local file.
- It read /etc/passwd directly from the remote machine through NFS.

/etc/passwd Contents

FIELDS CONTAINED

- Usernames
- User IDs
- Group IDs
- Home directories
- Login shells

```
msfadmin:x:1000:1000:...:/home/msfadmin:/bin/bash
```

The second field contains x — meaning passwords are stored separately in /etc/shadow. The passwd file itself does **not** contain password hashes on modern Linux systems.

9 Telnet Enumeration

```
telnet 10.174.253.161
```

Observed Banner


```
Warning: Never expose this VM to an untrusted network!
```

```
Login with msfadmin/msfadmin to get started
```

```
metasploitable login:
```

Findings

FINDINGS

- Telnet service reachable.
- Interactive login available.
- Server identifies itself as Metasploitable.
- Banner reveals default credentials (specific to this lab).

Logged in using Username: msfadmin / Password: msfadmin

```
whoami  
msfadmin
```

MEANING

- Successfully obtained an interactive Linux shell.
- Logged in as a normal user.
- Not root.

9 Enumeration vs Exploitation

Enumeration answers questions such as:

- Which services exist?
- Which versions are running?
- Can anonymous users log in?
- Can files be read?
- Can files be uploaded?
- What usernames exist?
- What directories are shared?

Exploitation answers: “*Can I use this information to gain unauthorized access or increase privileges?*”

Enumeration always comes first.

10 Key Mindset Learned

Follow this cycle for every service:

1	Observe
2	Form a hypothesis
3	Test it
4	Interpret the results
5	Record your findings

Worked Example

Observation	Anonymous FTP login works.
Hypothesis	Maybe uploads are allowed.
Test	<code>put testformeta.txt</code>
Result	553 Could not create file.
Conclusion	Anonymous FTP access is read-only.

This observe → hypothesize → test → conclude cycle is the core mindset of effective penetration testing.

Services Enumerated Today (Day 1)

COMPLETED

- Network connectivity
- Nmap scanning
- FTP
- SMB
- NFS
- Telnet

Next Session**UP NEXT**

- Apache HTTP
- Tomcat
- DNS
- Databases
- Java RMI
- IRC
- Remaining services

PART 2 — CONTINUED ENUMERATION — REMAINING SERVICES

Goal of This Enumeration Phase

The goal was to continue enumerating every remaining service discovered during the Nmap scan. Rather than attempting exploitation, the objective was to answer questions such as:

- What software is running?
- Which versions are installed?
- Does the service reveal useful information?
- Does it require authentication?
- Is there any obvious information disclosure or misconfiguration?

This completes the initial attack surface mapping of the target.

10 Apache HTTP Enumeration (Port 80)

Visited in browser:

```
http://10.174.253.161
```

PURPOSE

- Observe the default webpage.
- Identify visible web applications.
- Look for software names and version information.

Technology Fingerprinting

```
whatweb http://10.174.253.161
```

Purpose: identify technologies used by the website.

Result

RESULT

- Apache 2.2.8
- Ubuntu
- PHP 5.2.4
- WebDAV enabled
- X-Powered-By: PHP
- Default Metasploitable webpage

IMPORTANT LESSON

- Unlike Nmap, WhatWeb focuses specifically on web technologies.
- It identifies: web server, programming language, CMS/frameworks, HTTP headers, and web-related technologies.

Directory Enumeration

Performed directory enumeration to discover hidden pages.

Interesting Discoveries

DISCOVERIES

- phpMyAdmin
- TWiki
- phpinfo
- WebDAV directory
- CGI directory
- Server-status
- Test pages

PURPOSE

- Many web applications are not linked from the homepage.
- Directory enumeration attempts to discover them automatically.

HTTP Enumeration Findings

Software

SOFTWARE

- Apache 2.2.8
- PHP 5.2.4

Applications Discovered

APPLICATIONS

- phpMyAdmin
- TWiki
- phpinfo
- WebDAV
- Various default directories

IMPORTANT LESSON

- Finding applications does **not** mean exploiting them.
- Enumeration simply records what exists.

11 Apache Tomcat Enumeration (Port 8180)

Visited:

```
http://10.174.253.161:8180
```

Displayed: Apache Tomcat 5.5 default homepage.

PURPOSE

- Determine Tomcat version.
- Installed applications.
- Administrative interfaces.
- Example applications.

Information Revealed

The Homepage Disclosed

DISCLOSED

- Tomcat 5.5
- ROOT application
- Manager application
- Administration application
- Example JSP applications
- Example Servlets
- Documentation
- Configuration file names
- CATALINA_HOME references

Examples: `ROOT/index.jsp`, `tomcat-users.xml`, `web.xml`

These are not secrets but help identify how Tomcat is structured.

Tomcat Findings

Software

SOFTWARE

- Apache Tomcat 5.5

Applications Discovered

APPLICATIONS

- Tomcat Manager
- Tomcat Administration
- JSP Examples
- Servlet Examples
- Documentation

IMPORTANT LESSON

- Default applications remaining installed often increase attack surface.
- However, simply seeing them does not mean they are vulnerable.

Understanding Tomcat

Tomcat is a Java Web Application Server. Unlike Apache, which mainly serves webpages, Tomcat runs Java web applications.

Think of it as: “A server designed specifically for Java websites.”

12 MySQL Enumeration (Port 3306)

Connection attempt:

```
mysql -h 10.174.253.161 -u root -p
```

Initial Result

```
ERROR 2026 (HY000):  
TLS/SSL error: wrong version number
```

MEANING

- Modern MariaDB clients attempt encrypted connections.
- The very old MySQL server does not support modern TLS.
- The connection failed before authentication.

Disabling SSL

Connected using:

```
mysql --skip-ssl -h 10.174.253.161 -u root -p
```

MEANING

- `--skip-ssl` tells the client: "Do not attempt encrypted communication."
- Instead, connect using an unencrypted MySQL session.

Login Result

Pressed Enter without entering a password. Successfully entered:

```
MySQL [(none)]>  
Server version: 5.0.51a-3ubuntu5
```

Important Findings

FINDINGS

- Remote MySQL accessible
- Root account accepted blank password
- Full database access obtained

Understanding the SSL Error

The error did **NOT** indicate MySQL was offline, or an authentication failure. Instead it indicated:

“The client attempted modern TLS, while the old server could not understand it.”

MySQL Findings

Software

SOFTWARE

- MySQL 5.0.51a

Authentication

AUTHENTICATION

- Root account accepted blank password.

IMPORTANT LESSON

- Old services often require disabling modern encryption when communicating with legacy software.

13 PostgreSQL Enumeration (Port 5432)

Verified connectivity:

```
nc -nv 10.174.253.161 5432
```

Purpose: confirm that PostgreSQL is actively listening. Result: port open.

Version Detection

```
nmap -sV -p 5432
```

Result: PostgreSQL 8.3.x

Authentication Test

```
psql -h 10.174.253.161 -U postgres
```

Result: SSL error, followed by:

```
fe_sendauth: no password supplied
```

MEANING

- Server reachable.
- Authentication required.
- Modern SSL not supported.

PostgreSQL Findings

Software

SOFTWARE

- PostgreSQL 8.3.x

Authentication

AUTHENTICATION

- Password required.

SSL

SSL

- Legacy implementation incompatible with modern TLS.

IMPORTANT LESSON

- An exposed service does not automatically mean anonymous access.

14 DNS Enumeration (Port 53)

Version detection:

```
nmap -sV -p 53
```

Result: ISC BIND 9.4.2

Zone Transfer Test

```
dig @10.174.253.161 axfr
```

Purpose: check whether the DNS server allows full zone transfers.

Understanding Zone Transfers

A DNS Zone Transfer (AXFR) allows one DNS server to copy the complete DNS database from another DNS server.

Think of DNS as a phonebook. Normally you ask for one phone number. A zone transfer asks: "Give me the entire phonebook."

RISK IF MISCONFIGURED

- If misconfigured, an attacker could obtain:
- Hostnames
- Internal servers
- Subdomains
- Network layout

Result

RESULT

- Zone transfer was **NOT** allowed.
- The DNS server did not expose its internal DNS database.

DNS Findings

Software

SOFTWARE

- ISC BIND 9.4.2

Information Disclosure

DISCLOSURE

- Version only.

Zone Transfer

ZONE TRANSFER

- Blocked.

15 Java RMI Enumeration (Ports 1099 / 40380)

Version detection:

```
nmap -sV -p 1099,40380
```

Result: GNU Classpath RMI Registry — Ports: 1099, 40380

Understanding Java RMI

RMI stands for Remote Method Invocation. Purpose: allow one Java program to execute methods on another computer.

Think of it as: "Remote control for Java applications." Instead of requesting webpages, applications can request Java functions directly.

Registry Enumeration

```
nmap --script rmi-dumpregistry -p 1099
```

Purpose: attempt to list registered remote Java objects.

RESULT & MEANING

- Registry detected.
- No objects exposed.
- The service exists, but it does not reveal any callable objects through standard enumeration.

Java RMI Findings

Implementation

IMPLEMENTATION

- GNU Classpath RMI

Registry

REGISTRY

- Present

Objects Exposed

OBJECTS EXPOSED

- None discovered.

16 IRC Enumeration (Ports 6667 / 6697)

Version detection:

```
nmap -sV -p 6667,6697
```

Result: UnrealIRCd — Host: irc.Metasploitable.LAN

Understanding IRC

IRC stands for Internet Relay Chat — an older chat protocol used before modern messaging platforms.

Think of it as: “A very early version of Discord.”

Why Enumerate IRC?

- Server software
- Version
- Hostname
- Available ports

IRC Findings

Software

SOFTWARE
• UnrealIRCd

Ports

PORTS
• 6667 • 6697

Hostname Disclosed

HOSTNAME
• irc.Metasploitable.LAN

Difference Between Enumeration and Exploitation

Enumeration answers questions like:

- Which software is running?
- Which version is installed?
- Is authentication required?
- Are administrative interfaces exposed?
- What information does the service reveal?

Exploitation asks: *“Can these findings be used to gain unauthorized access?”*

Enumeration always comes first.

Key Mindset Learned

For every service, follow the same cycle:

1	Observe
2	Identify the software
3	Determine the version
4	Test how the service responds
5	Interpret the results
6	Record everything

Worked Example

Observation	MySQL is running.
Hypothesis	Maybe authentication is weak.
Test	Attempt connection.
Result	Root login without password.
Conclusion	Critical authentication misconfiguration discovered.

Overall Outcome

By the end of this enumeration phase, every major exposed service had been investigated.

Services Fully Enumerated (This Phase)

COMPLETED THIS PHASE

- Apache HTTP
- Apache Tomcat
- MySQL
- PostgreSQL
- DNS
- Java RMI
- IRC

Combined With Earlier Work On

EARLIER WORK

- FTP
- SMB
- NFS
- Telnet

RESULT

- This completed the initial attack surface mapping of the Metasploitable 2 machine.

NEXT PHASE

- The next phase of a penetration test would be to analyze these findings and determine which services present the highest-priority targets for deeper investigation and controlled exploitation.